

Mapeo GQM + Métricas PASTA+STRIDE a Requisitos Normativos

Nota: mapeo orientativo, centrado en España y marcos europeos (NIS2, ENS, DORA, España Digital, etc.).
[web:21][web:24][web:27][web:30]

Objetivo GQM	Métrica	Normas / Estrategias relacionadas	Comentario
G1 – Proteger infraestructuras y servicios esenciales	M1.1 – % OSE con Threat Modeling	NIS2 (gestión basada en riesgo), Plan Nacional de Ciberseguridad, ENS (análisis de riesgos) [web:21][web:27]	La adopción de Threat Modeling apoya el deber de gestionar riesgos y proteger servicios esenciales.
G1, G2	M1.2 – % OSE con revisión anual de modelos	NIS2, ENS (revisión periódica), ISO 27001 (mejora continua) [web:21][web:27]	Refuerza la necesidad de gestión continua del riesgo, no sólo análisis puntual.
G2	M1.3 – % proyectos críticos con Threat Modeling en diseño	España Digital 2025 (desarrollo seguro), guías de desarrollo seguro, OWASP SAMM [web:27][web:39]	Alinea el diseño de servicios digitales con seguridad por diseño.
G1	M2.1.x – Incidentes STRIDE por año	NIS2 (notificación de incidentes), Plan Nacional, Ciberestrategias sectoriales [web:21] [web:53][web:56]	Permite evaluar cumplimiento de deberes de notificación y efectividad de medidas.
G1	M2.2.x – Tasa de incidentes STRIDE por sector	NIS2 (operadores esenciales por sector), estrategias sectoriales (energía, salud, finanzas) [web:21] [web:27]	Apoya análisis sectoriales exigidos y priorización de acciones.
G1	M2.3.x – Tendencia anual incidentes STRIDE	Plan Nacional de Ciberseguridad, indicadores de desempeño [web:21]	Facilita evaluación longitudinal del impacto de las políticas.
G1, G3	M3.1 – % OSE con ≥ 1 ejercicio anual	NIS2 (pruebas y ejercicios), ENISA recomendaciones de ciber crisis [web:21] [web:24]	Da medida de cumplimiento de prácticas de ensayo de respuesta.
G1, G3	M3.2 – N ^o medio de sistemas cubiertos en ejercicios	Planes de ciber crisis nacionales, ENS (continuidad) [web:21] [web:27]	Evalúa profundidad de los ejercicios más allá del mero “tick de cumplimiento”.
G3	M3.3 – % ejercicios con planes de acción implementados	ISO 27001 (gestión de incidentes y acciones de mejora), ENS [web:27]	Demuestra la traducción de ejercicios a mejoras reales.

G1, G3	M4.1 – MTTR crítico	NIS2 (minimizar impacto), planes de continuidad y recuperación, ENS [web:21][web:27]	Métrica clave de resiliencia exigida implícitamente en requisitos de continuidad.
G3	M4.2 – Distribución MTTR por sector	Estrategias sectoriales de resiliencia, NCS Index [web:53] [web:56]	Permite a reguladores sectoriales comparar desempeño.
G2, G3	M4.3 – Correlación MTTR vs. madurez Threat Modeling	Plan Nacional, España Digital (madurez de capacidades) [web:21] [web:27][web:30]	Apoya la tesis de que la madurez técnica reduce impacto operativo.
G2, G4	M5.1 – % entidades que integran Threat Modeling en riesgo	NIS2 (gestión de riesgos en órgano de dirección), DORA (riesgo TIC integrado), ENS [web:21][web:24] [web:27]	Mide si la seguridad técnica y la gestión de riesgo corporativo hablan entre sí.
G3	M5.2 – % entidades que vinculan PASTA con continuidad y ejercicios	ENS (análisis de impacto en negocio, continuidad), NIS2 [web:21][web:27]	Refleja el grado de integración entre análisis preventivo y respuesta.
G4	M5.3 – % entidades que usan Threat Modeling para ROI	DORA (evaluación económica del riesgo TIC), marcos de reporting financiero [web:24]	Conecta ciberseguridad con la gestión financiera exigida regulatoriamente.

Este mapeo puede servir como base para anexos en estrategias nacionales, guías de INCIBE/CCN y documentación de cumplimiento de operadores esenciales.